

The Active Directory Attacks Playbook

A complete, detailed guide to Active Directory attack techniques — from enumeration to domain compromise

From a single low-privilege foothold to Domain Admin, this playbook builds the attack-path intuition and tool fluency that penetration testers and defenders both need to understand Active Directory risk.

Author: Swastik Sagar
Final-year Computer Science Undergraduate
SOC Analyst Intern

August 5, 2026

Preface

Active Directory runs the majority of the world’s corporate networks, and its attack surface is enormous precisely because it was designed decades ago around convenience and backward compatibility, not against a modern threat model. Almost every real-world ransomware intrusion that spreads beyond a single machine passes through AD at some point — Kerberoasting, pass-the-hash, and DCSync are not theoretical techniques, they are routine, daily findings in enterprise environments.

This playbook walks the attack chain in the order it actually unfolds in a real engagement: understanding AD’s own structure and authentication protocols first, then enumeration, then the credential-attack techniques that convert a low-privilege foothold into higher access, then lateral movement and persistence, and finally — because understanding the attack is only half the value — how each technique is actually detected and defended against.

Authorization required

Every technique in this book is intended strictly for authorized penetration testing, red team engagements, and personal lab environments. Using these techniques against systems you don’t own or have explicit written authorization to test is illegal in most jurisdictions.

What this book covers

- Active Directory fundamentals: domains, forests, OUs, trusts, GPOs
- Kerberos and NTLM authentication, in enough depth to understand the attacks
- Enumeration with BloodHound, PowerView, and native tools
- Kerberoasting and AS-REP Roasting
- Pass-the-Hash and Pass-the-Ticket
- Golden Tickets, Silver Tickets, and the krbtgt account
- DCSync and credential dumping
- Lateral movement techniques
- Persistence techniques
- Detection and defense for every attack covered

Swastik Sagar

Contents

Preface	i
1 Active Directory Fundamentals	1
1.1 What Active Directory is	1
1.2 Core structural concepts	1
1.3 Group Policy	1
1.4 Trusts	2
2 Authentication Protocols	3
2.1 NTLM, briefly	3
2.2 Kerberos, in the depth attacks require	3
3 Enumeration	4
3.1 What to look for	4
3.2 BloodHound	4
3.3 PowerView	4
3.4 Native/living-off-the-land enumeration	4
4 Kerberoasting and AS-REP Roasting	6
4.1 Kerberoasting	6
4.2 AS-REP Roasting	6
4.3 Detection and defense	7
5 Pass-the-Hash and Pass-the-Ticket	8
5.1 Pass-the-Hash (PtH)	8
5.2 Pass-the-Ticket (PtT)	8
5.3 Detection and defense	8
6 Golden and Silver Tickets	9
6.1 The krbtgt account	9
6.2 Golden Tickets	9
6.3 Silver Tickets	9
6.4 Detection and defense	10

7 DCSync and Credential Dumping	11
7.1 DCSync	11
7.2 LSASS credential dumping	11
7.3 Detection and defense	11
8 Lateral Movement	12
8.1 Common lateral movement techniques	12
8.2 Unconstrained and constrained delegation	12
8.3 Detection and defense	12
9 Persistence	13
9.1 Common AD persistence techniques	13
9.2 Detection and defense	13
10 Detection and Defense Summary	14
10.1 Priority hardening steps	14
10.2 High-value events to monitor	14

Active Directory Fundamentals

1.1 What Active Directory is

Active Directory (AD) is Microsoft's directory service — a centralized database of users, computers, groups, and policies, along with the authentication and authorization infrastructure that lets one set of credentials work across an entire corporate network.

1.2 Core structural concepts

Concept	Meaning
Domain	A logical boundary of users/computers sharing a common directory database
Forest	A collection of one or more domains sharing a common schema and global catalog
Organizational Unit (OU)	A container for organizing objects and applying Group Policy
Domain Controller (DC)	A server holding a copy of the domain's directory database, handles authentication
Trust	A relationship allowing users in one domain to authenticate to resources in another

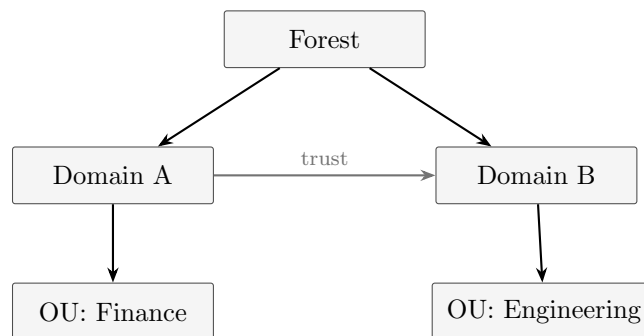


Figure 1.1. *A minimal forest with two domains, each containing its own organizational structure, linked by a trust.*

1.3 Group Policy

Group Policy Objects (GPOs) push configuration — security settings, software installation, login scripts — to users and computers within an OU. From an attacker's perspective, GPOs are also a powerful lateral movement and persistence vector: anyone with write access to a GPO applied broadly can push a malicious scheduled task or script to every machine it touches.

1.4 Trusts

Trust type	Notes
Parent-child	Automatic, within the same forest
Cross-forest	Explicitly configured between two separate forests
One-way	Users in the trusted domain can access the trusting domain, not vice versa
Transitive	Extends automatically through a chain of trusts

Trusts as an attack path

A misconfigured or overly broad trust can let an attacker who compromises one domain pivot directly into a second, fully separate domain — trust relationships are a standard part of any thorough AD attack-path review.

Authentication Protocols

2.1 NTLM, briefly

NTLM is a legacy challenge-response authentication protocol, still supported for backward compatibility. The server challenges the client, the client responds with a value derived from its password hash, and the server (or a domain controller on its behalf) verifies it — the password itself is never sent, but the hash-derived response is exactly what enables pass-the-hash attacks.

2.2 Kerberos, in the depth attacks require

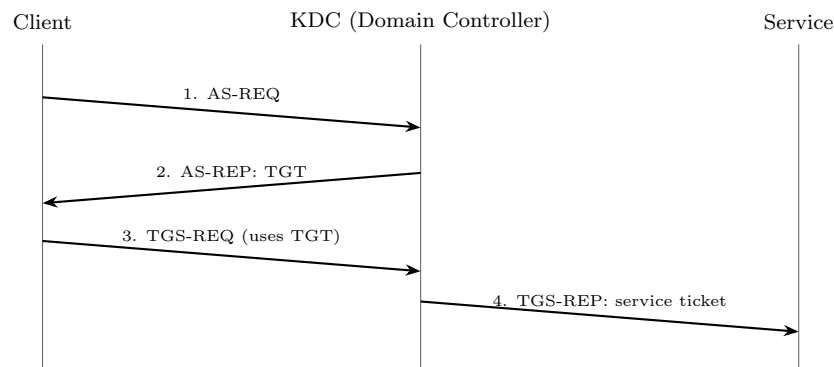


Figure 2.1. *The core Kerberos exchange. Steps 1–2 happen once per session; steps 3–4 repeat for every service accessed.*

Term	Meaning
KDC	Key Distribution Center, runs on every Domain Controller
TGT	Ticket Granting Ticket, proves the user authenticated, encrypted with the krbtgt account's key
TGS	Ticket Granting Service, issues service tickets in exchange for a valid TGT
Service ticket	Encrypted with the target service account's password hash, presented to that service
SPN	Service Principal Name, identifies a service instance tied to an account

Why this matters for attacks

Every major Kerberos attack in this book abuses one specific property of this exchange: service tickets are encrypted with a hash derived from the target account's password, and if that account has a weak password, an attacker who can request a ticket can crack it completely offline, with no further interaction with the domain controller.

Enumeration

3.1 What to look for

- Users, groups, and their memberships, especially nested/indirect admin rights
- Computers, especially ones with unconstrained delegation configured
- ACLs granting unusual write/reset-password rights over other objects
- Service accounts with SPNs set (Kerberoastable by definition)
- Trust relationships and their direction

3.2 BloodHound

BloodHound collects AD relationships (group memberships, ACLs, sessions, trust edges) and represents them as a graph, then runs pathfinding algorithms to answer the question that actually matters: what is the shortest path from where I am now to Domain Admin?

Collecting data with SharpHound

```
SharpHound.exe -c All
```

Why graph analysis beats manual review

Privilege escalation paths in AD are rarely a single obvious misconfiguration — they're usually a chain of several individually unremarkable permissions (nested group membership plus one ACL plus one cached session) that only becomes visible when the whole graph is analyzed together, which is exactly what BloodHound automates.

3.3 PowerView

Common PowerView enumeration

```
Get-NetUser -SPN Get-NetGroupMember "Domain Admins" Get-NetComputer
-Unconstrained Get-DomainTrust Find-InterestingDomainAcl
```

3.4 Native/living-off-the-land enumeration

No extra tools required

```
net user /domain net group "Domain Admins" /domain nltest /domain_trusts setspn -T
domain.local -Q */*
```


Detection note

Native command enumeration blends in far better than dropping BloodHound's collector binary to disk — from a defensive standpoint, unusual LDAP query volume is a more reliable detection signal than watching for any one specific tool.

Kerberoasting and AS-REP Roasting

4.1 Kerberoasting

Any authenticated domain user can request a service ticket for any account with an SPN set — no special privileges required. Since that ticket is encrypted with the service account's password hash, an attacker can request tickets for every SPN-having account in the domain, then crack them completely offline, with zero further interaction with the DC after the initial request.

Requesting and cracking service tickets

```
-- Request tickets for all SPN accounts: Rubeus.exe kerberoast
/outfile:hashes.txt
-- Crack offline: hashcat -m 13100 hashes.txt rockyou.txt
```

Why service accounts are the weak point

Service accounts are disproportionately likely to have old, weak, or never-rotated passwords, since they're configured once and often forgotten — making them the highest-value Kerberoasting targets in almost every real environment.

4.2 AS-REP Roasting

If an account has *Do not require Kerberos preauthentication* enabled, an attacker can request an AS-REP for that account with no credentials at all, and the returned data is encrypted with a key derived from the account's password — crackable offline exactly like a Kerberoasted ticket, but requiring no valid credentials to even attempt.

AS-REP Roasting with Rubeus

```
Rubeus.exe asreproast /outfile:asrep_hashes.txt hashcat -m 18200 asrep_hashes.txt
rockyou.txt
```

4.3 Detection and defense

Defense	Effect
Long, random service account passwords	Makes offline cracking computationally infeasible
Group Managed Service Accounts (gMSA)	Automatically rotated, effectively immune to roasting
Disable unneeded preauth exemptions	Closes AS-REP Roasting for accounts that don't need it
Monitor Event ID 4769	Spikes in service ticket requests, especially for many distinct SPNs from one account, are a strong Kerberoasting signal

Pass-the-Hash and Pass-the-Ticket

5.1 Pass-the-Hash (PtH)

NTLM authentication only ever needs the password *hash*, never the plaintext password — so an attacker who has dumped an NTLM hash (from LSASS, SAM, or elsewhere) can authenticate directly with the hash, without ever knowing or cracking the actual password.

Pass-the-hash with a captured NTLM hash

```
mimikatz.exe "sekurlsa::pth /user:jdoe /domain:corp.local /ntlm:<hash> /run:cmd.exe"
```

5.2 Pass-the-Ticket (PtT)

The Kerberos equivalent: instead of a password or hash, an attacker reuses a captured Kerberos ticket (TGT or service ticket) directly — extracted from memory on a compromised host and injected into a new session elsewhere.

Extracting and reusing a ticket

```
mimikatz.exe "sekurlsa::tickets /export" mimikatz.exe "kerberos::ptt ticket.kirbi"
```

Why both matter together

PtH works anywhere NTLM is accepted; PtT works anywhere Kerberos is accepted. Disabling NTLM entirely closes PtH but Kerberos tickets remain a viable path — a mature defense has to address both authentication protocols, not just one.

5.3 Detection and defense

- Enable Credential Guard to prevent LSASS credential extraction in the first place
- Restrict local admin accounts from being valid across many hosts (LAPS-style unique local passwords)
- Monitor Event ID 4624 with Logon Type 9 (NewCredentials) and unusual Logon Type 3 patterns
- Alert on ticket lifetimes or properties inconsistent with normal issuance (a hallmark of injected tickets)

Golden and Silver Tickets

6.1 The krbtgt account

Every TGT issued in a domain is encrypted with the password hash of a single special account: **krbtgt**. Whoever holds that hash can forge a completely valid TGT for any user, including one that doesn't actually exist, entirely offline.

6.2 Golden Tickets

Forging a Golden Ticket with mimikatz

```
mimikatz.exe "kerberos::golden /user:fakeadmin /domain:corp.local
/sid:<domain-sid> /krbtgt:<krbtgt-hash> /ptt"
```

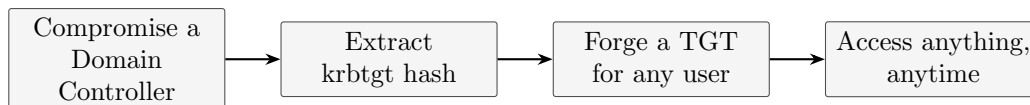


Figure 6.1. Once the krbtgt hash is compromised, an attacker can mint valid tickets indefinitely – this is why a Golden Ticket compromise requires resetting krbtgt, not just changing passwords.

Why Golden Tickets are so dangerous

A forged ticket is cryptographically indistinguishable from a legitimate one to any service that trusts the domain — the only real remediation is resetting the krbtgt password (twice, due to a two-password history) to invalidate every ticket ever issued with the old hash.

6.3 Silver Tickets

A Silver Ticket forges a *service* ticket directly, using that specific service account's hash rather than krbtgt's — narrower in scope than a Golden Ticket, but critically, it never touches the Domain Controller at all, since the DC isn't involved in validating a service ticket once issued, making it significantly harder to detect.

Forging a Silver Ticket

```
mimikatz.exe "kerberos::golden /user:fakeadmin /domain:corp.local
/sid:<domain-sid> /target:server.corp.local /service:cifs /rc4:<service-hash>
/ptt"
```

6.4 Detection and defense

Defense	Effect
Reset krbtgt password (twice) regularly	Limits the blast radius of an undetected krbtgt compromise
Monitor for TGTs with anomalous life-times/properties	Forged tickets often deviate subtly from normal issuance defaults
Tier your admin model (Tiering / ESAE)	Limits which hosts a Domain Admin credential is ever exposed on
Monitor Event ID 4624/4634 for accounts with no corresponding 4768/4769	A logon with no matching ticket-request event is a Silver Ticket indicator

DCSync and Credential Dumping

7.1 DCSync

DCSync abuses the legitimate replication protocol Domain Controllers use to stay in sync with each other — any account with replication rights (**Replicating Directory Changes** and **Replicating Directory Changes All**) can request password hashes for any account directly from a DC, without ever running code on the DC itself.

DCSync with mimikatz

```
mimikatz.exe "lsadump::dcsync /domain:corp.local /user:krbtgt"
```

Who normally has this right

Domain Admins and Domain Controllers themselves have replication rights by design — DCSync becomes an attack the moment a lower-privileged account is misconfigured to also hold it, which is exactly the kind of misconfiguration BloodHound is built to surface.

7.2 LSASS credential dumping

LSASS (Local Security Authority Subsystem Service) holds credential material in memory for active sessions — dumping its memory is one of the most common ways to harvest plaintext passwords, NTLM hashes, and Kerberos tickets from a single compromised host.

Common LSASS dumping approaches

```
-- mimikatz: mimikatz.exe "sekurlsa::logonpasswords"  
-- via a memory dump for offline analysis: procdump.exe -ma lsass.exe lsass.dmp
```

7.3 Detection and defense

- Enable Credential Guard, which isolates LSASS secrets from even an admin-level process
- Monitor Sysmon Event ID 10 for process access to `lsass.exe`, especially from unusual parent processes
- Restrict and audit accounts holding replication rights
- Monitor for the specific replication request pattern DCSync generates, distinguishable from normal DC-to-DC replication traffic

Lateral Movement

8.1 Common lateral movement techniques

Technique	Mechanism
PsExec-style execution	Copies a binary to ADMIN\$ and runs it via the Service Control Manager
WMI	Remote command execution via Windows Management Instrumentation
WinRM / PowerShell Remoting	Remote PowerShell sessions over WS-Management
RDP	Interactive remote desktop, often using harvested credentials
Pass-the-Hash/Ticket	Reuses captured credentials rather than needing plaintext

Why living-off-the-land tools dominate

PsExec, WMI, and WinRM are all legitimate administrative tools already present on Windows — using them for lateral movement avoids dropping any new binary to disk, which is precisely why they're preferred over custom malware for this stage of an intrusion.

8.2 Unconstrained and constrained delegation

A computer account configured for **unconstrained delegation** caches a copy of any TGT presented to it — compromising that machine means harvesting the TGTs of every user who ever authenticated to it, potentially including a Domain Admin. **Constrained delegation** narrows this to specific services, and **resource-based constrained delegation** shifts the trust decision to the target resource itself.

8.3 Detection and defense

- Segment networks so lateral movement between tiers requires crossing a monitored boundary
- Monitor Event ID 4648 (explicit credential logon) for unusual account/host pairings
- Avoid unconstrained delegation entirely where possible; audit any computer account that has it
- Deploy EDR coverage focused on process-injection and credential-access behaviors, not just file signatures

Persistence

9.1 Common AD persistence techniques

Technique	Mechanism
Golden Ticket	Forge valid TGTs indefinitely using the krbtgt hash
AdminSDHolder abuse	Modifying the ACL template applied periodically to protected admin accounts
DSRM password reuse	Directory Services Restore Mode account offers a local-admin-equivalent backdoor on a DC
Skeleton Key	Malware patching LSASS on a DC to accept a master password for any account
Malicious GPO	A GPO pushing a backdoor or scheduled task broadly across the domain

AdminSDHolder specifically

AdminSDHolder's ACL is reapplied to all protected group members roughly every hour by the SDProp process — an attacker who modifies the AdminSDHolder ACL itself gets their backdoor permission silently reapplied to every protected account on the same schedule, making it a notably durable persistence mechanism.

9.2 Detection and defense

- Baseline and alert on any change to the AdminSDHolder object
- Regularly audit GPO contents and modification history, not just who has edit rights
- Monitor DSRM account usage, which should be effectively never in normal operation
- Treat krbtgt compromise as requiring a full password reset (twice), not just incident cleanup

Detection and Defense Summary

10.1 Priority hardening steps

- Enforce long, unique passwords for every service account; move to gMSAs where possible
- Enable Credential Guard fleet-wide to blunt LSASS-based credential theft
- Implement a tiered administration model so Domain Admin credentials are never exposed on lower-tier hosts
- Deploy unique local administrator passwords (LAPS) to blunt lateral movement via shared local admin credentials
- Audit and minimize delegation and replication rights on a recurring schedule, not just once

10.2 High-value events to monitor

Event ID	Watch for
4768/4769	Kerberoasting patterns: many distinct SPNs requested by one account
4648	Explicit credential use, especially from unexpected host/account pairs
4662	Directory replication access, the core DCSync signature
4670	Permissions changed on an object, including AdminSDHolder
1102	Security log cleared

The recurring theme

Nearly every technique in this book relies on the same underlying fact: Kerberos and NTLM were designed for interoperability and backward compatibility, not for resisting an attacker who already has a foothold. Detection therefore has to focus heavily on behavioral anomalies — unusual account/host pairings, atypical ticket properties, and rights that don't match the account's normal role — rather than any single indicator alone.